

BRUTE

ÍNDICE DE CONTENIDOS

ALCANCE.....	4
FUERA DE ALCANCE.....	4
GLOSARIO.....	5
MODELO DE DATOS.....	9
DIAGRAMA DE LA BASE DE DATOS.....	9
<i>Users</i>	9
<i>User Phones</i>	10
<i>User Profiles</i>	10
<i>Credentials</i>	10
<i>Tokens</i>	11
Activation.....	12
Password Reset.....	12
Pre Auth.....	12
Refresh.....	12
Session.....	12
Password Change.....	12
Email Change.....	13
MFA Reset.....	13
Phone Change.....	13
Fraud Flag.....	13
Reactivation.....	13
REQUERIMIENTOS FUNCIONALES.....	14
REGISTRO DE USUARIOS.....	14
<i>Registro de perfiles</i>	14
<i>Registro de credenciales</i>	15
Registro de credenciales de perfiles privilegiados.....	16
Registro de credenciales de perfiles no privilegiados.....	17
INICIO DE SESIÓN.....	19
OPERACIONES SENSIBLES.....	22
<i>Reinicio de contraseña</i>	23
<i>Cambio de contraseña</i>	24
<i>Cambio de correo</i>	25
<i>Cambio de teléfono</i>	26
CIERRE DE SESIÓN.....	27
<i>Cierre de sesión local</i>	28
<i>Cierre seleccionado de sesión en otros dispositivos</i>	28
<i>Cierre de sesión en todos los dispositivos</i>	28
REQUERIMIENTOS NO FUNCIONALES.....	29
PORTABILIDAD.....	29
ESCALABILIDAD.....	29
MANTENIBILIDAD.....	30
DISPONIBILIDAD.....	30
RENDIMIENTO.....	30
SEGURIDAD.....	31

TRAZABILIDAD	32
DECISIONES TÉCNICAS	32
STACK	32
<i>TypeScript</i>	32
<i>NestJS</i>	32
<i>TypeORM</i>	33
<i>SQL Server</i>	33
ARQUITECTURA	33
<i>Separación de identidad, perfil y credenciales</i>	33
<i>Doble perfil por usuario</i>	34
<i>El correo como canal de comunicación universal</i>	34
MODELO DE DATOS	34
<i>“user_id” como identificador de identidad</i>	34
<i>Estados de credencial</i>	34
<i>Índice de filtrado “UQ_Credentials_Identifier_Active”</i>	35
<i>Evaluación “lazy” de “locked_until”</i>	35
SEGURIDAD.....	35
<i>Uso de “crypto.randomBytes(32)” para generación de tokens</i>	35
<i>Uso de “SHA-256” para el hasheo de tokens</i>	35
<i>BCrypt para hasheo de contraseñas</i>	35
<i>MFA obligatorio</i>	36
<i>Bloqueo progresivo</i>	36
CASOS LÍMITE	36
FALLO DEL SERVIDOR DE CORREO DURANTE UNA OPERACIÓN SENSIBLE	36
COLISIÓN DE HASH DE TOKENS.....	36
CONDICIÓN DE CARRERA EN EL REGISTRO SIMULTÁNEO.....	36
CIERRE DE SESIÓN SOBRE UNA SESIÓN YA CERRADA	37
USUARIO NO PRIVILEGIADO SIN ACCESO AL CORREO DURANTE REACTIVACIÓN.....	37

ÍNDICE DE FIGURAS

Figura #1 – Diagrama de la base de datos	9
---	----------

ÍNDICE DE TABLAS

Tabla #1 – Estados de las credenciales	11
Tabla #2 – Tokens	11
Tabla #3 – ‘Centinela’ en registro de perfiles privilegiados.....	17
Tabla #4 – ‘Centinela’ en registro de perfiles no privilegiados.....	19
Tabla #5 – Posibles escenarios de inicio de sesión	22

Objetivo

BRUTE es un sistema reutilizable de autenticación y autorización de usuarios, diseñado para integrarse en múltiples proyectos propios, que minimiza la superficie de ataque mediante separación de identidad, perfil y credenciales, y protege contra vectores de secuestro de cuentas en operaciones sensibles.

Alcance

- *Frontend* de muestra.
- Registro básico de usuarios.
- Soporte de doble perfil por usuario (perfil privilegiado y perfil no privilegiado).
- Hasheo de contraseñas.
- Inscripción y configuración del MFA.
 - Generación de secretos.
 - Cifrado de secretos.
 - Asignación de secretos.
- Emisión de tokens revocables de validación de sesión u operaciones sensibles.
- Autenticar usuarios.
- Autorizar usuarios.
- Operaciones sensibles.
 - Cambio de contraseña.
 - Cambio de correo electrónico.
 - Cambio de teléfono.
- Notificación a usuarios sobre inicio y resultado de operaciones sensibles.
- Cancelación o reversión de cambios efectuados por operaciones sensibles fraudulentas.
- Bloqueo de acceso por intentos accesos fallidos.

Fuera de alcance

- Gestión avanzada de roles (permisos granulares).
- *Frontend* elaborado.

Glosario

- **Algoritmo:** Conjunto ordenado y finito de instrucciones o pasos definidos para resolver un problema o realizar una tarea específica.
- **API:** Conjunto de reglas e interfaces que permite la comunicación e intercambio de información entre aplicaciones o servicios.
- **Archivos huérfanos:** Archivos almacenados que ya no mantienen una relación válida con los registros o recursos del sistema que les dieron origen.
- **Atomicidad:** Propiedad de una transacción que garantiza que todas sus operaciones se ejecuten completamente o, en caso de error, ninguna de ellas tiene efecto.
- **Autenticación:** Proceso de comprobar la identidad del usuario antes de brindar acceso.
- **Autorización:** Proceso de comprobar si un usuario tiene la capacidad de efectuar una acción.
- **Borrado lógico:** Técnica mediante la cual un registro se marca como eliminado sin ser removido físicamente de su almacenamiento, permitiendo conservar su información para auditoría o recuperación.
- **Cifrar:** Proceso de transformar datos legibles en un formato ilegible mediante un algoritmo criptográfico y una clave, con el fin de proteger su confidencialidad. Conocido comúnmente como: “encriptar”.
- **Código QR:** Código bidimensional que almacena información codificada para ser leída mediante un dispositivo compatible.
- **Constraints:** Reglas o condiciones que los datos deben cumplir para garantizar su validez, consistencia e integridad.
- **Consumidor:** Negocio o sistema que implemente **BRUTE**.
- **Cookie:** Fragmento de información que un servidor almacena en el navegador del usuario para conservar datos entre solicitudes HTTP, como identificadores de sesión, preferencias o información de autenticación.
- **Credenciales:** Datos de un usuario que ayudan a autenticar su identidad (identificador, contraseña, etc.).
- **Cron Job:** Tarea programada para ejecutarse automáticamente en intervalos o momentos específicos.
- **CRUD:** Conjunto de operaciones básicas para gestionar información: crear (*Create*), consultar (*Read*), actualizar (*Update*) y eliminar (*Delete*).

- **Denegación de servicios:** Ataque cuyo objetivo es impedir o degradar la disponibilidad de un sistema o servicio mediante el consumo excesivo de sus recursos.
- **DTO (*Data Transfer Object*):** Objeto utilizado para transportar datos entre componentes o servicios, sin contener lógica de negocio.
- **Endpoint:** Punto de acceso de una API mediante el cual un cliente puede invocar una operación o acceder a un recurso.
- **Estado del MFA:** Indicador interno del sistema que refleja si la cuenta de un usuario tiene un método de autenticación asociado y disponible para su uso durante el proceso de autenticación.
- **Excepción:** Evento que representa una condición anómala o un error ocurrido durante la ejecución de un programa y que puede ser gestionado por el sistema.
- **Framework:** Conjunto de herramientas, componentes y convenciones que proporciona una estructura base para facilitar el desarrollo de aplicaciones.
- **Frontend:** Componente de una aplicación responsable de la interfaz de usuario y de la interacción directa con este.
- **Función orquestadora:** Función encargada de coordinar la ejecución de otras funciones para completar un proceso, sin concentrar la lógica de negocio en una única implementación.
- **Función:** Bloque de código que encapsula una tarea específica y puede recibir datos de entrada para producir un resultado.
- **Guard:** Componente encargado de determinar si una solicitud cumple las condiciones necesarias para acceder a un recurso o ejecutar una operación.
- **Hardcodeado:** Valor definido directamente en el código fuente, en lugar de obtenerse desde una configuración, una base de datos o una fuente externa.
- **Hash:** Valor de longitud fija generado mediante una función matemática a partir de un dato de entrada que se almacena en lugar del dato original cuando se requiere proteger su confidencialidad o verificar su autenticidad.
- **Hasheo:** Proceso que genera un hash.
- **Identificador:** Dato de un usuario que permite distinguirlo de manera única.
- **Inscripción y configuración del MFA:** Proceso de asociar un método de autenticación multifactor (por sus siglas en inglés, “MFA”: *Multifactor Authentication*) a la cuenta de un usuario para habilitar su uso en futuras autenticaciones.
- **Log:** Registro cronológico de eventos, operaciones o errores generados por un sistema durante su ejecución.

- **Operaciones sensibles:** Operaciones que modifican información crítica de una cuenta o sus mecanismos de autenticación, y que, por su impacto, requieren mecanismos de protección y validación adicionales antes de ser ejecutadas.
- **OTP (One-Time Password):** Contraseña de un solo uso, generada para autenticar una operación o un inicio de sesión y válida durante un tiempo limitado o para una única utilización.
- **Parámetro:** Dato que una función recibe como entrada para ejecutar su lógica.
- **Perfil no privilegiado:** Perfil usuario que dispone únicamente de los permisos necesarios para acceder a funcionalidades o recursos comunes del sistema, sin acceso a funcionalidades o recursos restringidos.
- **Perfil privilegiado:** Perfil de usuario que cuenta con permisos elevados para acceder a funcionalidades o recursos restringidos dentro del sistema.
- **Perfil:** Conjunto de información asociada a un usuario dentro del sistema, como sus datos personales y el nivel de acceso que posee.
- **Rate limiting:** Mecanismo que limita la cantidad de solicitudes que un cliente puede realizar a un recurso o servicio durante un periodo de tiempo determinado.
- **Rollback:** Reversión de los cambios realizados por una transacción cuando esta no puede completarse correctamente, restaurando el estado previo.
- **Secretos:** Datos confidenciales que una aplicación o servicio utiliza para autenticarse o acceder a otros recursos, y que requieren un almacenamiento y una administración seguros para evitar accesos no autorizados.
- **Superficie de ataque:** Conjunto de puntos de entrada, interfaces y recursos de un sistema que podrían ser explotados para comprometer su seguridad.
- **Texto plano:** Información almacenada o transmitida sin aplicar mecanismos de cifrado u otra forma de protección criptográfica.
- **Tipado:** Característica de un lenguaje de programación que define el tipo de dato que puede almacenar una variable, recibir un parámetro o devolver una función.
- **Token:** Valor generado por el sistema que representa una identidad, una autorización o un propósito específico, y que se utiliza para validar solicitudes, acceder a recursos o ejecutar determinadas operaciones durante un período de tiempo definido.
- **Transacción:** Conjunto de operaciones ejecutadas como una única unidad de trabajo, de modo que todas se completan correctamente o ninguna produce cambios permanentes.

- **Trazabilidad:** Capacidad de registrar, identificar y reconstruir las actividades relacionadas con la autenticación y el acceso a un sistema, permitiendo identificar los eventos, los usuarios involucrados y el momento en el que ocurrieron.
- **URL:** Dirección que identifica la ubicación de un recurso y el mecanismo utilizado para acceder a él a través de una red.
- **User-Agent:** Cabecera HTTP enviada por el navegador web que identifica el cliente que origina una solicitud. Puede incluir información como el nombre y la versión del navegador, el sistema operativo y otros datos del entorno de ejecución.
- **Usuario:** Persona que interactúa con el sistema mediante una cuenta registrada.
- **UX (User Experience):** Conjunto de aspectos relacionados con la experiencia que tiene un usuario al interactuar con un sistema, incluyendo la facilidad de uso, accesibilidad, la eficiencia y la satisfacción durante la realización de sus tareas.
- **Vectores de secuestro de cuentas:** Técnicas o mecanismos mediante los cuales un atacante puede obtener el control no autorizado de la cuenta de un usuario.

Modelo de datos

Diagrama de la base de datos

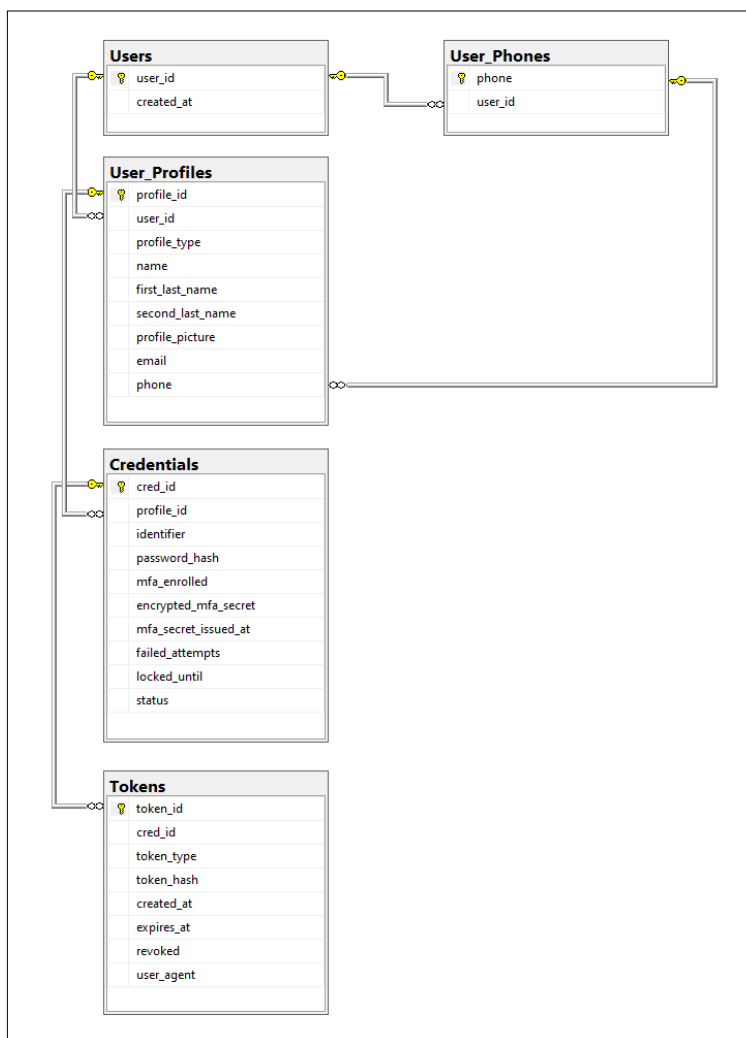


Figura #1 – Diagrama de la base de datos

BRUTE plantea una base para registro de usuarios, a raíz de la siguiente premisa: sin usuarios, no existen credenciales.

Users

“Users” es la tabla principal, funciona como un repositorio general para todos los usuarios registrados en el sistema, y en esta versión, está diseñada de tal forma que “user_id” representa el número de cédula costarricense, y “created_at” es un valor de trazabilidad. El diseño de “user_id” asume un contexto específico en el que el sistema será utilizado, únicamente, en Costa Rica, por lo que portarlo fuera del país implicaría rediseñar esta columna. Es importante tomar en consideración que la base de datos asegura que “user_id” almacene datos en formato correcto de cédula (9 dígitos), mas no valida su autenticidad.

User Phones

“User_Phones” tiene el objetivo de asegurar que un número telefónico esté registrado, únicamente, a un usuario, complementado el diseño de la tabla: “User_Profiles”. “phone” está diseñada de tal forma que asegure que se almacenen datos en formato correcto de números de teléfono costarricenses (8 dígitos), y “user_id” define la relación entre entidades.

User Profiles

“User_Profiles” almacena qué tipo de perfil es: *privileged* o *unprivileged*, e información general del usuario: nombre (“name”), apellidos (“first_last_name” y “second_last_name”), foto de perfil (“profile_picture”), correo electrónico (“email”) y número de teléfono (“phone”). Esto no es un diseño rígido, y puede ser modificado a necesidad del consumidor. Tal y como se mencionó anteriormente, **BRUTE** plantea un registro básico de usuarios para ejemplificar flujos comunes. Además, “User_Profiles” asegura que no exista más de un perfil del mismo tipo por usuario, y asegura que “email” siempre sea almacenado en formato correcto.

El tipo de perfil, además de diferenciar cuáles son perfiles privilegiados y cuáles son perfiles comunes, se complementa con las tablas “Credentials” y “Tokens” para separar las credenciales; es decir, cada perfil tiene sus propias credenciales, impidiendo que un perfil privilegiado comparta credenciales con un perfil común, reduciendo los vectores de secuestro de cuentas.

Credentials

“Credentials” almacena: el identificador (“identifier”), el hash de la contraseña (“password_hash”), el estado de enlazamiento del MFA (“mfa_enrolled”), el secreto cifrado del MFA (“encrypted_mfa_secret”), la marca de tiempo de cuando se generó el secreto del MFA (“mfa_secret_issued_at”), la cantidad de intentos de acceso fallidos (“failed_attempts”), el periodo de bloqueo (“locked_until”), y el estado de las credenciales (“status”), que es una de las columnas más importantes de la tabla. “status” determina lo siguiente:

Estado	Significado
PENDING	Credenciales pendientes de activación.
ACTIVATED	Credenciales operativas.
LOCKED	Bloqueada por cantidad de intentos de acceso fallidos.

BLOCKED	Bloqueada por cantidad excesiva de intentos de acceso fallidos, o posible secuestro de cuenta.
COMPROMISED	Credenciales comprometidas.
REACTIVATING	Credenciales pendientes de reactivación.
DISABLED	Cuenta deshabilitada por borrado lógico, o decisión del consumidor.

Tabla #1 – Estados de las credenciales

En **BRUTE**, el identificador es único, no puede repetirse en entre credenciales.

Tokens

“Tokens” almacena la relación con las credenciales que la emite (“cred_id”), el tipo de token (“token_type”), el hash del token (“token_hash”), cuándo fue creada (“created_at”), cuándo expira (“expires_at”), si se encuentra revocada (“revoked”), y el *user-agent* (“user_agent”). El tipo de token determina para qué es válida la *token*:

Tipo	Duración	Significado
ACTIVATION	24 horas	Activación de cuenta.
PASSWORD_RESET	1 hora	Reinicio de contraseña.
PRE_AUTH	2 minutos	Credenciales (no OTP) validadas.
REFRESH	48 horas o 6 meses	Refresco de sesión.
SESSION	15 minutos	Sesión.
PASSWORD_CHANGE	1 hora	Cambio de contraseña.
EMAIL_CHANGE	12 horas	Cambio de correo.
MFA_RESET	15 minutos	Reinicio de MFA.
PHONE_CHANGE	12 horas	Cambio de teléfono.
FRAUD_FLAG	2 horas	Indicador de posible fraude.
REACTIVATION	24 horas	Reactivación de cuenta.

Tabla #2 – Tokens

Activation

La token de tipo “ACTIVATION” será emitida tras el registro del perfil, y, siempre será entregada al usuario mediante un correo de seguimiento, donde estará embebida en una URL que lo redirigirá a una interfaz donde podrá completar su proceso de registro. En caso de no ser utilizada, expirará pasadas las 24 horas, volviéndose inutilizable.

Password Reset

La token de tipo “PASSWORD_RESET” será emitida cuando el usuario seleccione la opción: “¿Olvidó su contraseña?”, y siempre será entregada al usuario mediante un correo de seguimiento, donde estará embebida en una URL que lo redirigirá a una interfaz donde podrá completar el proceso de reinicio de contraseña. En caso de no ser utilizada, expirará tras 1 hora, volviéndose inutilizable.

Pre Auth

La token de tipo “PRE_AUTH” será emitida cuando el usuario complete la validación de sus credenciales de primer factor (“identifier” + contraseña) de forma exitosa. Esta token será entregada al usuario mediante una *cookie*, y servirá para autorizar el uso del *endpoint* que valida la integridad de la OTP. Esta token tendrá una duración de 2 minutos, tras ese periodo de tiempo, expirará volviéndose inutilizable.

Refresh

La token de tipo “REFRESH” será emitida cuando el usuario inicie sesión. Esta token será entregada al usuario mediante una *cookie*, y servirá para determinar por cuánto tiempo deben emitirse tokens de tipo “SESSION”, que son las que autorizan al usuario a navegar a través de rutas privadas, o ejecutar determinadas acciones. Este tipo de token, por sí sola, no es efectiva. Esta token tendrá una duración de 48 horas, o 6 meses (en caso de que el usuario seleccione la opción: “Recuérdame”). Tras ese periodo de tiempo, la token expirará volviéndose inutilizable.

Session

La token de tipo “SESSION” será emitida cuando el usuario inicie sesión, o cuando interactúe con el sistema del consumidor sin que existan tokens del mismo tipo, y tenga una token de tipo “REFRESH” activa. Esta token será entregada al usuario mediante una *cookie*, y servirá para autorizar al usuario a navegar a través de rutas privadas, o ejecutar determinadas acciones. Esta token tendrá una duración de 15 minutos, tras ese periodo de tiempo, la token expirará volviéndose inutilizable.

Password Change

La token de tipo “PASSWORD_CHANGE” será emitida cuando el usuario seleccione la opción: “Cambiar contraseña”, y siempre será entregada al usuario mediante un correo de seguimiento, donde estará

embebida en una URL que lo redirigirá a una interfaz donde podrá completar el proceso de cambio de contraseña. En caso de no ser utilizada, expirará tras 1 hora, volviéndose inutilizable.

Email Change

La token de tipo “EMAIL_CHANGE” será emitida cuando el usuario seleccione la opción: “Cambiar correo electrónico”, y siempre será entregada al usuario mediante un correo de seguimiento, donde estará embebida en una URL que lo redirigirá a una interfaz donde podrá completar el proceso de cambio de correo. En caso de no ser utilizada, expirará pasadas las 12 horas, volviéndose inutilizable.

MFA Reset

La token de tipo “MFA_RESET” será emitida en dos contextos distintos: cuando el usuario complete el proceso de cambio de dirección de correo electrónico, o cuando el usuario inicie sesión con credenciales en estado “REACTIVATING”. En ambos casos, será entregada al usuario mediante un correo de seguimiento, donde estará embebida en una URL que lo redirigirá a una interfaz donde podrá completar el proceso de reenlazamiento del MFA. Esta token tendrá una duración de 15 minutos, tras ese periodo de tiempo, expirará volviéndose inutilizable.

Phone Change

La token de tipo “PHONE_CHANGE” será emitida cuando el usuario seleccione la opción: “Cambiar teléfono”, y siempre será entregada al usuario mediante un correo de seguimiento, donde estará embebida en una URL que lo redirigirá a una interfaz donde podrá completar el proceso de cambio de teléfono. En caso de no ser utilizada, expirará pasadas las 12 horas, volviéndose inutilizable.

Fraud Flag

La token de tipo “FRAUD_FLAG” será emitida cada vez que, en una cuenta, se inicie sesión desde un dispositivo nuevo, o, cada vez que se confirme la finalización de una operación sensible, y siempre será entregada al usuario mediante el correo de notificación referente al nuevo inicio de sesión detectado, o en el correo referente a la operación sensible en sí, donde estará embebida en una URL que lo redirigirá a una interfaz donde podrá reportar un posible secuestro de cuenta. Este reporte, le indicará a **BRUTE** que debe eliminar la contraseña, y la información del MFA de las credenciales del usuario, además de actualizar su estado a: “BLOCKED”. En caso de no ser utilizada, expirará pasadas las 2 horas, volviéndose inutilizable.

Reactivation

La token de tipo “REACTIVATION” puede ser emitida, únicamente, por un perfil privilegiado, en situaciones que ameriten el desbloqueo de credenciales de un usuario. El criterio de emisión queda a definición del consumidor, ya que implica el diseño de protocolos y mecanismos de confirmación de

identidad. En caso de no ser utilizada, expirará pasadas las 24 horas, volviéndose inutilizable. El criterio de reemisión queda a definición del consumidor.

Requerimientos funcionales

Registro de usuarios

Registro de perfiles

BRUTE debe manejar dos flujos distintos: registro de perfiles privilegiados, y registro de perfiles no privilegiados. Independientemente del contexto, la interfaz proveerá al usuario con los campos necesarios para ingresar la información personal requerida por el modelo de datos, y la información adicional que el consumidor requiera.

Una vez que el usuario envíe la información, **BRUTE** verificará lo siguiente:

- Verificará si la identificación del usuario ya estaba registrada previamente.
 - En caso de que estuviera previamente registrada, verificará si el usuario que se está intentando registrar ya estaba previamente registrado con mismo tipo de perfil, según corresponda.
 - Si estaba previamente registrado con el mismo tipo de perfil, el usuario que esté efectuando el registro recibirá una respuesta negativa genérica que le indicará que la información que se está intentando registrar, ya está en uso.
 1. En el contexto de registro de perfiles no privilegiados, revelar qué información está en uso puede representar una fuga de información confidencial, por lo que no se debe especificar qué información está en uso, ya que el registro se está efectuando en una interfaz pública.
 2. En el contexto de registro de perfiles privilegiados, sí se debe especificar qué información está en uso, ya que el registro se está efectuando en un entorno controlado.
 - Si no estaba previamente registrado con el mismo tipo de perfil, verificará si el teléfono que el usuario está intentando registrar ya está registrado bajo un “userId” distinto.
 - Si está registrado bajo un “userId” distinto, el usuario que esté efectuando el registro recibirá una respuesta negativa genérica que le indicará que la información que se está intentando registrar, ya está en uso.
 1. En el contexto de registro de perfiles no privilegiados, revelar qué información está en uso puede representar una fuga de información

confidencial, por lo que no se debe especificar qué información está en uso, ya que el registro se está efectuando en una interfaz pública.

2. En el contexto de registro de perfiles privilegiados, sí se debe especificar qué información está en uso, ya que el registro se está efectuando en un entorno controlado.

- Si está registrado bajo el mismo “userId”, quiere decir que el teléfono ya ha sido registrado por, o para el usuario, en un tipo de perfil distinto. Por lo tanto, la función ejecutará el registro respectivo.
- Si no estaba previamente registrada, la función debe ejecutar los registros respectivos.

En caso de que durante el registro de la información ocurra algún error de formato, el usuario que esté efectuando el registro recibirá un mensaje que le indicará qué está fallando, y por qué, sea por cantidad de caracteres, formato de la información (en el caso de la dirección de correo, o del teléfono), e inclusive, el formato de la foto de perfil, ya que solo se permiten los siguientes: “.jpg”, “.png”, o “.webp”, o su tamaño. Cualquier error durante este proceso evitará que la información ingresada se guarde.

Registro de credenciales

El registro de credenciales depende expresamente del registro del perfil, y al igual que este, debe contemplar dos flujos: registro de credenciales de perfiles privilegiados, y registro de credenciales de perfiles no privilegiados; sin embargo, ambos procesos coinciden en un requisito: el enlazamiento de la cuenta a un MFA es obligatorio.

BRUTE determina que el enlazamiento de las cuentas de los usuarios a un MFA es indispensable, ya que no solo refuerza la protección de las cuentas de los usuarios, sino que también refuerza la seguridad del consumidor, y la información que maneja.

BRUTE tiene la capacidad de procesar múltiples procesos de registro que utilicen la misma información, para evitar escenarios de denegación de servicios, que pueden darse cuando un usuario malintencionado intente iniciar múltiples procesos de registro con información ajena, para "reservarla" para ese proceso en sí, y bloquear procesos legítimos. No obstante, solo uno de esos procesos podrá ser completado, y una vez que una cuenta se actualice como operativa, el resto de procesos serán invalidados.

La información asociada al resto de procesos de registro será, eventualmente, eliminada, y los correos correspondientes a esos procesos dejarán de ser funcionales; es decir, si un usuario recibe un correo referente a un proceso de registro que no inició voluntariamente, puede ignorarlo. En el caso de que este mismo usuario reciba un correo de notificación que confirme que el proceso de registro se completó

exitosamente, se infiere que un atacante está intentando suplantar su identidad (utilizando su información), y que tiene acceso a su correo. **BRUTE**, en los correos de notificación de confirmación de finalización de procesos de registro, incluirá la opción "No fui yo", que lo redirigirá a una interfaz que le permitirá al usuario legítimo bloquear la cuenta recién creada para evitar su uso fraudulento, además de informarle que su correo esté, posiblemente, comprometido, sugiriéndole confirmar que nadie más tiene acceso a él, y que de lo contrario, se apegue a los protocolos de seguridad de su proveedor de correo.

Registro de credenciales de perfiles privilegiados

Una vez que el registro del perfil haya finalizado, el usuario recibirá un correo de **BRUTE** que incluirá una opción que le permitirá al usuario continuar con su proceso de registro. Además, el correo le indicará al usuario que, para completar el proceso de registro, cuenta con un plazo de 24 horas, y que en caso de que no sea completado durante ese plazo, deberá contactar con el soporte.

Al seleccionar esta opción, el usuario será redirigido a una interfaz que lo proveerá con los campos para ingresar sus futuras credenciales: contraseña, y las credenciales adicionales que el consumidor requiera. Durante este proceso, pueden presentarse varios escenarios. **BRUTE** cuenta con un ‘Centinela’ que le permite evaluar ciertos datos de las credenciales del usuario, y definir el protocolo a seguir:

‘Centinela’ evalúa:			
“password_hash”	“mfa_enrolled”	“mfa_secret_issued_at”	Descripción
NULL	FALSE	NULL	‘Centinela’ indica al <i>frontend</i> que el usuario no ha completado el registro de sus credenciales. El <i>frontend</i> proveerá al usuario con los campos para ingresar sus futuras credenciales: contraseña, y las credenciales adicionales que el consumidor requiera.
EXISTS	FALSE	NULL	‘Centinela’ indica al <i>frontend</i> que el usuario ya completó el registro de sus credenciales; sin embargo, la información del MFA no ha sido generada, por lo que BRUTE la generará y la retornará una única vez al <i>frontend</i> para que el usuario la visualice y la utilice según necesite. BRUTE retorna: el secreto en texto plano, y un código QR. Este escenario no es parte del flujo normal, e indica un fallo del servidor en proceso de ejecución, o un fallo de red.

EXISTS	FALSE	TIME STAMP	‘Centinela’ indica al <i>frontend</i> que el usuario ya ha completado el registro de sus credenciales, y determina que el secreto del MFA y el código QR ya fue generado, lo que sugiere la existencia de dos escenarios: 1. Usuario enlazó la cuenta. 2. Usuario no enlazó la cuenta. En ambos escenarios, el ‘Centinela’ debe indicarle al <i>frontend</i> que debe mostrarle dos opciones al usuario: 1. “Necesito un nuevo código QR”. 2. “Tengo mi código”. La primera opción solicitará a BRUTE la generación de un nuevo secreto, de su respectivo código QR, y sobrescribirá los datos anteriores (tanto “encrypted_mfa_secret” como “mfa_secret_issued_at”). La segunda opción le mostrará al usuario el campo para ingresar la OTP, que puede desencadenar dos subescenarios: 1. OTP válida: BRUTE actualizará el estado de las credenciales del usuario, habilitándolas para su uso, y finalizando el proceso de registro. El usuario será redirigido a la interfaz de inicio de sesión. 2. OTP inválida: El usuario recibirá una respuesta negativa genérica que le indicará que la OTP es incorrecta.
--------	-------	------------	---

Tabla #3 – ‘Centinela’ en registro de perfiles privilegiados

Registro de credenciales de perfiles no privilegiados

Una vez que el registro del perfil haya finalizado, que en este contexto, tiene la particularidad de que el usuario define la contraseña en el mismo momento que define el resto de su información, el usuario recibirá un correo de **BRUTE** que incluirá una opción que le permitirá al usuario continuar con su proceso de registro. Además, el correo le indicará al usuario que, para completar el proceso de registro, cuenta con un plazo de 24 horas, y que en caso de que no sea completado durante ese plazo, deberá iniciar el proceso desde el principio.

Al seleccionar esta opción, el usuario será redirigido a una interfaz que lo proveerá con la información del MFA, para que el usuario la visualice y la utilice según necesite. Esta información es generada por **BRUTE** en el mismo momento que el usuario es redirigido a esta interfaz, y retorna: el secreto en texto plano, y un código QR. Durante este proceso, pueden presentarse varios escenarios. **BRUTE** cuenta con un ‘Centinela’ que le permite evaluar ciertos datos de las credenciales del usuario, y definir el protocolo a seguir:

Función ‘Centinela’ evalúa:			
“password_hash”	“mfa_enrolled”	“mfa_secret_issued_at”	Descripción
NULL	FALSE	NULL	‘Centinela’ determina que existe una token de activación válida; sin embargo, la contraseña no ha sido registrada, y el secreto del MFA no ha sido generado. Este escenario no es parte del flujo normal, e indica un fallo del servidor, o un fallo de red. BRUTE le indicará al <i>frontend</i> que debe redirigir al usuario a iniciar, nuevamente, el proceso de registro desde el principio.
EXISTS	FALSE	NULL	‘Centinela’ determina que el usuario ya completó la fase inicial de registro, por lo que BRUTE genera el secreto del MFA y el código QR y lo retorna al <i>frontend</i>.
EXISTS	FALSE	TIME STAMP	‘Centinela’ determina que el usuario ya completó la fase inicial de registro, y determina que el secreto del MFA ya fue generado, lo que sugiere la existencia de dos escenarios: 1. Usuario enlazó la cuenta. 2. Usuario no enlazó la cuenta. En ambos escenarios, el ‘Centinela’ debe indicarle al <i>frontend</i> que debe mostrarle dos opciones al usuario: 1. “Necesito un nuevo código QR”. 2. “Tengo mi código”. La primera opción solicitará a BRUTE la generación de un nuevo secreto, de su respectivo código QR, y sobrescribirá los datos anteriores (tanto

			“encrypted_mfa_secret”, como “mfa_secret_issued_at”). La segunda opción le mostrará al usuario el campo para ingresar la OTP, que puede desencadenar dos subescenarios: 1. OTP válida: BRUTE actualizará el estado de las credenciales del usuario, habilitándolas para su uso, y finalizando el proceso de registro. El usuario será redirigido a la interfaz de inicio de sesión. 2. OTP inválida: El usuario recibirá una respuesta negativa genérica que le indicará que la OTP es incorrecta.
--	--	--	---

Tabla #4 – ‘Centinela’ en registro de perfiles no privilegiados

Inicio de sesión

En **BRUTE**, el inicio de sesión es uno de los procesos más importantes. No solo por su objetivo en sí, que es ser la principal barrera de protección de acceso a las cuentas de los usuarios del sistema consumidor, sino también por su valor técnico, ya que es el punto en el que convergen los resultados de múltiples procesos de vital importancia: registro, definición de credenciales, configuración del MFA, etc.

A nivel interno, se evalúan diversos datos para determinar si el inicio de sesión es legítimo, o no. A raíz de esto, deben tomarse en consideración los siguientes escenarios:

BRUTE evalúa:			
“identifier”	“password_hash”	“status”	Resultado
NULL	NULL	NULL	Credenciales inexistentes. El usuario recibirá una respuesta negativa genérica que indicará que las credenciales son incorrectas.
CORRECTO	INCORRECTO	“PENDING”	Credenciales incorrectas. El usuario recibirá una respuesta negativa genérica que indicará que las credenciales son incorrectas.
CORRECTO	CORRECTO	“PENDING”	Credenciales correctas; sin embargo, están pendientes de activación. El usuario recibirá una respuesta negativa genérica que le indicará que debe revisar su correo para completar el proceso de registro.

CORRECTO	INCORRECTO	“ACTIVATED”	Credenciales incorrectas; pero, operativas. El usuario recibirá una respuesta negativa genérica que le indicará que las credenciales son incorrectas. Internamente, BRUTE registrará la cantidad de intentos de acceso fallidos, cuya acumulación desencadenará un bloqueo temporal, o indefinido. • 5 intentos fallidos: Bloqueo de 5 minutos. • 6 intentos fallidos: Bloqueo de 10 minutos. • 7 intentos fallidos: Bloqueo de 15 minutos. • 8 intentos fallidos: Bloqueo de 30 minutos. • 9 intentos fallidos: Bloqueo indefinido.
CORRECTO	CORRECTO	“ACTIVATED”	Credenciales correctas y operativas. El <i>frontend</i> proveerá al usuario con el campo para ingresar la OTP. En este contexto, existen dos posibles subescenarios: 1. La OTP es válida: El usuario será redirigido a la interfaz principal de la plataforma. 1.1. Si el usuario contaba con intentos de acceso fallidos acumulados, el contador será reiniciado. 1.2. Si el usuario marcó la opción “Recuérdame”, BRUTE mantendrá su sesión activa durante 6 meses, de lo contrario, su sesión durará 48 horas. 1.3. BRUTE identificará si se está iniciando sesión desde un nuevo dispositivo, y, en caso de ser así, enviará un correo de notificación al usuario, que incluirá la opción: “No fui yo”, para reportar inicios de sesión no voluntarios. 2. La OTP no es válida: El usuario recibirá una respuesta negativa genérica que le indicará que la OTP no es correcta. Internamente, BRUTE contabilizará esto como un intento de acceso fallido.
CORRECTO	INCORRECTO	“LOCKED”	Credenciales incorrectas. El usuario recibirá una respuesta negativa genérica que le indicará que las credenciales son incorrectas.

CORRECTO	CORRECTO	“LOCKED”	Credenciales correctas; pero, bloqueadas temporalmente por exceso de intentos de acceso fallidos. BRUTE determinará si el bloqueo ya ha pasado. En este contexto, existen dos posibles subescenarios: 1. El bloqueo ha pasado: BRUTE interpreta que las credenciales son correctas y operativas. El <i>frontend</i> proveerá al usuario con el campo para ingresar la OTP. En este contexto, existen dos posibles subescenarios: 1.1. La OTP es válida: El usuario será redirigido a la interfaz principal de la plataforma. 1.1.1. Si el usuario contaba con intentos de acceso fallidos acumulados, el contador será reiniciado. 1.1.2. Si el usuario marcó la opción “Recuérdame”, BRUTE mantendrá su sesión activa durante 6 meses, de lo contrario, su sesión durará 48 horas. 1.1.3. BRUTE identificará si se está iniciando sesión desde un nuevo dispositivo, y, en caso de ser así, enviará un correo de notificación al usuario, que incluirá la opción: “No fui yo”, para reportar inicios de sesión no voluntarios. 1.2. La OTP no es válida: El usuario recibirá una respuesta negativa genérica que le indicará que la OTP no es correcta. Internamente, BRUTE contabilizará esto como un intento de acceso fallido. 2. El bloqueo no ha pasado: El usuario recibirá una respuesta negativa genérica que le
----------	----------	----------	---

			indicará que el acceso se encuentra bloqueado temporalmente debido a un exceso de intentos de acceso fallidos, y, que por favor, intente más tarde.
CORRECTO	NO SE EVALÚA	“BLOCKED”	Credenciales bloqueadas permanentemente. El usuario recibirá una respuesta negativa genérica que le indicará que el acceso se encuentra suspendido indefinidamente, y que para restablecerlo, debe entrar en contacto con el soporte.
CORRECTO	NO SE EVALÚA	“COMPROMISED”	Credenciales comprometidas. El usuario recibirá una respuesta negativa genérica que le indicará que el acceso se encuentra suspendido indefinidamente, y que para restablecerlo, debe entrar en contacto con el soporte.
CORRECTO	INCORRECTO	“REACTIVATING”	Credenciales incorrectas; sin embargo, están pendientes de reactivación. El usuario recibirá una respuesta negativa genérica que le indicará que las credenciales son incorrectas. Intentos de acceso fallidos persistidos serán bloqueados por <i>rate limiting</i> .
CORRECTO	CORRECTO	“REACTIVATING”	Credenciales correctas; sin embargo, están pendientes de reactivación. BRUTE generará una token de reinicio de MFA y la enviará en un correo, embebida en una URL adjunta, que lo redirigirá a una interfaz donde podrá completar el proceso de reenlazamiento del MFA.
CORRECTO	NO SE EVALÚA	“DISABLED”	Credenciales deshabilitadas. El usuario recibirá una respuesta negativa genérica que le indicará que la cuenta ha sido deshabilitada.

Tabla #5 – Posibles escenarios de inicio de sesión

Operaciones sensibles

En **BRUTE**, las operaciones sensibles son: reinicios de contraseña, cambios de contraseña, cambios de correo y cambios de teléfono. Estas operaciones son uno de los principales vectores de secuestro de cuentas, por lo que su protección se convierte en una prioridad absoluta. **BRUTE** ofrece estrictos protocolos y mecanismos uniformes para todas las operaciones sensibles, que no solo son capaces de proteger las cuentas de los usuarios del consumidor e informarles sobre todos aquellos cambios que las modifiquen, sino

que es capaz de detectar e informar a los usuarios de la vulneración de sus recursos críticos externos (correos, plataformas de MFA).

Cada proceso de revalidación de identidad tendrá un límite de 5 intentos fallidos. En caso de que el usuario, o un posible atacante, falle 5 veces a la hora de revalidar su identidad, **BRUTE** revocará la token correspondiente al proceso que se está ejecutando, y le indicará que debe iniciar el proceso desde el principio.

Reinicio de contraseña

El reinicio de contraseña es una de las operaciones sensibles más críticas, ya que puede iniciarse sin una sesión activa y validada, y es contemplada cuando un usuario no recuerda su contraseña.

Cuando el usuario seleccione la opción de: “¿Olvidó su contraseña?”, será redirigido a una interfaz donde deberá ingresar su dirección de correo. Si la dirección de correo está realmente registrada, **BRUTE** enviará un correo con una URL adjunta, que lo redirigirá a una interfaz donde podrá definir la nueva contraseña; sin embargo, para enviarla, la interfaz le solicitará que ingrese la OTP emitida por su MFA.

Si **BRUTE** determina que la OTP es válida, se ejecutará el reinicio y el usuario será redirigido a la interfaz de inicio de sesión, y recibirá un correo de notificación que le informará que el reinicio ha sido efectuado con éxito. Si **BRUTE** determina que la OTP es inválida, el reinicio nunca podrá ser ejecutado, ya que el usuario no puede validar su identidad.

En un escenario de intento de secuestro de cuenta, el usuario recibirá el correo con la URL adjunta para iniciar el proceso de reinicio que no solicitó. El correo explicará que si el usuario no inició el proceso voluntariamente, puede ignorarlo, ya que sin el acceso a la OTP, el reinicio nunca podrá ser ejecutado; sin embargo, si recibe el correo de notificación que le informa que el reinicio se ha efectuado con éxito, este correo traerá consigo una URL específica a utilizar en estos escenarios, bajo la opción: “No fui yo”. Si el usuario selecciona esta opción, **BRUTE** ejecutará un protocolo de protección que eliminará sus credenciales (contraseña y MFA), y las bloqueará indefinidamente con el objetivo de inhabilitar el acceso a la cuenta.

El usuario recibirá un correo de notificación que le informará que su cuenta ha sido bloqueada indefinidamente para evitar su uso fraudulento, además de informar que tanto su correo como su MFA han sido vulnerados. Es importante esclarecer: para ejecutar un reinicio de contraseña, se necesita acceso tanto al correo como al MFA, por lo que si el proceso se completó, y no por voluntad del usuario, la situación sugiere que ambos recursos fueron vulnerados. El correo de notificación, además de sugerir recuperar el

control de sus recursos externos, adjuntará los pasos a seguir para restablecer el acceso a su cuenta, definidos por los protocolos de confirmación de identidad definidos por el consumidor.

Cambio de contraseña

El cambio de contraseña requiere una sesión activa y validada, y podrá iniciarse desde la interfaz donde el usuario visualiza la información de su perfil.

Cuando el usuario seleccione la opción de: “Cambiar contraseña”, **BRUTE** enviará un correo con una URL adjunta que lo redirigirá a una interfaz donde podrá definir la nueva contraseña; sin embargo, para enviarla, la interfaz le solicitará que ingrese la contraseña actual, y la OTP emitida por su MFA.

Si **BRUTE** determina que tanto la contraseña como la OTP son válidas, se ejecutará el cambio, el usuario será redirigido a la interfaz donde visualiza la información de su perfil, y recibirá un correo de notificación que le informará que el cambio ha sido efectuado con éxito. Si **BRUTE** determina que la contraseña, o la OTP es inválida, el cambio nunca podrá ser ejecutado, ya que el usuario no puede revalidar su identidad. A pesar de contar con una sesión activa y validada, puede tratarse de un escenario en el que el usuario dejó la sesión abierta en un dispositivo accesible para otras personas, por lo que la revalidación resulta indispensable.

En un escenario de intento de secuestro de cuenta, el usuario recibirá el correo con la URL adjunta para iniciar el proceso de cambio de contraseña que no solicitó. El correo explicará que si el usuario no inició el proceso voluntariamente, debería acceder a su cuenta lo antes posible, y utilizar la opción: “Cerrar sesión en todos los dispositivos”, que estará disponible en la interfaz donde visualiza la información de su perfil. Esta medida se encargará de revocar el acceso a la cuenta en todos los dispositivos activos, además de frenar todas las operaciones sensibles en curso; sin embargo, si recibe el correo de notificación que le informa que el cambio se ha efectuado con éxito, este correo traerá consigo una URL específica a utilizar en estos escenarios, bajo la opción: “No fui yo”. Si el usuario selecciona esta opción, **BRUTE** ejecutará un protocolo de protección que eliminará sus credenciales (contraseña y MFA), y las bloqueará indefinidamente con el objetivo de inhabilitar el acceso a la cuenta.

El usuario recibirá un correo de notificación que le informará que su cuenta ha sido bloqueada indefinidamente para evitar su uso fraudulento, además de informar que tanto su correo como su MFA han sido vulnerados. Es importante esclarecer: para ejecutar un cambio de contraseña, se necesita acceso tanto al correo, como a la contraseña actual, y al MFA, por lo que si el proceso se completó, y no por voluntad del usuario, la situación sugiere que sus recursos fueron vulnerados. El correo de notificación, además de

sugerir recuperar el control de sus recursos externos, adjuntará los pasos a seguir para restablecer el acceso a su cuenta, definidos por los protocolos de confirmación de identidad definidos por el consumidor.

Cambio de correo

El cambio de correo es otra de las operaciones sensibles más críticas, ya que representa un cambio en el canal de comunicación entre el usuario y el consumidor, el cual es responsable de entregar los recursos necesarios para que el usuario gestione su cuenta. Esta operación requiere una sesión activa y validada, y podrá iniciarse desde la interfaz donde el usuario visualiza la información de su perfil.

Cuando el usuario seleccione la opción de: “Cambiar correo electrónico”, **BRUTE** enviará un correo con una URL adjunta que lo redirigirá a una interfaz donde podrá definir la nueva dirección de correo; sin embargo, para enviarla, la interfaz le solicitará que ingrese la contraseña actual, y la OTP emitida por su MFA.

Si **BRUTE** determina que tanto la contraseña como la OTP son válidas, se le indicará al usuario que recibirá un correo de seguimiento en la nueva dirección de correo, que incluirá una opción para confirmar el cambio. Si **BRUTE** determina que la contraseña, o la OTP es inválida, el cambio nunca podrá ser ejecutado, ya que el usuario no puede revalidar su identidad. A pesar de contar con una sesión activa y validada, puede tratarse de un escenario en el que el usuario dejó la sesión abierta en un dispositivo accesible para otras personas, por lo que la revalidación resulta indispensable.

En un escenario de intento de secuestro de cuenta, el usuario recibirá el correo con la URL adjunta para iniciar el proceso de cambio de correo que no solicitó. El correo explicará que si el usuario no inició el proceso voluntariamente, debería acceder a su cuenta lo antes posible, y utilizar la opción: “Cerrar sesión en todos los dispositivos”, que estará disponible en la interfaz donde visualiza la información de su perfil. Esta medida se encargará de cerrar las sesiones abiertas en todos los dispositivos, además de frenar todas las operaciones sensibles en curso.

En el correo de seguimiento, el usuario encontrará la opción para confirmar el cambio. En caso de que el usuario se equivocara a la hora de escribir la nueva dirección, y este correo termina en un correo ajeno, o inactivo, pueden presentarse los siguientes escenarios:

- **El correo terminó en un correo ajeno.**
 - El dueño ignora el correo, tal y como indica el correo en esta situación, y el proceso expira tras las 12 horas.

- El dueño no ignora el correo, y decide intentar confirmar el cambio, convirtiéndolo en un atacante. El atacante deberá ingresar la contraseña actual y la OTP emitida por el MFA.
 - El atacante ingresa correctamente las credenciales, por lo que el usuario recibirá la confirmación de cambio de correo en la dirección de correo original, que traerá consigo una URL específica a utilizar en estos escenarios, bajo la opción: “No fui yo”. Si el usuario selecciona esta opción, **BRUTE** ejecutará un protocolo de protección que eliminará sus credenciales (contraseña y MFA), y las bloqueará indefinidamente con el objetivo de inhabilitar el acceso a la cuenta.
 - El atacante falla 5 veces al ingresar las credenciales, por lo que **BRUTE** anulará el proceso revocando la token.
- **El correo terminó en un correo inactivo.**
 - El correo en cuestión será ignorado, y el proceso expirará tras las 12 horas.

Si el usuario confirma el cambio (que requerirá volver a ingresar la contraseña actual, y la OTP emitida por su MFA), **BRUTE** cerrará las sesiones abiertas en todos los dispositivos, eliminará la información del MFA, y efectuará las actualizaciones correspondientes. Posteriormente, generará una token de reinicio de MFA, la adjuntará a una URL, y la enviará a través de un correo de seguimiento a la nueva dirección de correo del usuario, que lo redirigirá a una interfaz donde **BRUTE** generará la nueva información del MFA y la retornará para que el usuario pueda visualizarla y utilizarla según necesite.

En este punto, dependiendo del contexto del usuario (es decir, dependiendo de si es un perfil privilegiado, o un perfil no privilegiado), deben consultarse los posibles escenarios que cubre el ‘centinela’ en el registro de credenciales de perfiles privilegiados, o en el registro de credenciales de perfiles no privilegiados, definidos secciones atrás.

Cambio de teléfono

El cambio de teléfono requiere una sesión activa y validada, y podrá iniciarse desde la interfaz donde el usuario visualiza la información de su perfil.

Cuando el usuario seleccione la opción de: “Cambiar teléfono”, **BRUTE** enviará un correo con una URL adjunta que lo redirigirá a una interfaz donde podrá definir el nuevo teléfono; sin embargo, para enviarla, la interfaz le solicitará que ingrese la contraseña actual, y la OTP emitida por su MFA.

Si **BRUTE** determina que tanto la contraseña como la OTP son válidas, se ejecutará el cambio, el usuario será redirigido a la interfaz donde visualiza la información de su perfil, y recibirá un correo de notificación que le informará que el cambio ha sido efectuado con éxito. Si **BRUTE** determina que la

contraseña, o la OTP es inválida, el cambio nunca podrá ser ejecutado, ya que el usuario no puede revalidar su identidad. A pesar de contar con una sesión activa y validada, puede tratarse de un escenario en el que el usuario dejó la sesión abierta en un dispositivo accesible para otras personas, por lo que la revalidación resulta indispensable.

En un escenario de intento de secuestro de cuenta, el usuario recibirá el correo con la URL adjunta para iniciar el proceso de cambio de teléfono que no solicitó. El correo explicará que si el usuario no inició el proceso voluntariamente, debería acceder a su cuenta lo antes posibles, y utilizar la opción: “Cerrar sesión en todos los dispositivos”, que estará disponible en la interfaz donde visualiza la información de su perfil. Esta medida se encargará de revocar el acceso a la cuenta en todos los dispositivos activos, además de frenar todas las operaciones sensibles en curso; sin embargo, si recibe el correo de notificación que le informa que el cambio se ha efectuado con éxito, este correo traerá consigo una URL específica a utilizar en estos escenarios, bajo la opción: “No fui yo”. Si el usuario selecciona esta opción, **BRUTE** ejecutará un protocolo de protección que eliminará sus credenciales (contraseña y MFA), y las bloqueará indefinidamente con el objetivo de inhabilitar el acceso a la cuenta.

El usuario recibirá un correo de notificación que le informará que su cuenta ha sido bloqueada indefinidamente para evitar su uso fraudulento, además de informar que tanto su correo como su MFA han sido vulnerados. Es importante esclarecer: para ejecutar un cambio de teléfono, se necesita acceso tanto al correo como a la contraseña actual, y al MFA, por lo que si el proceso se completó, y no por voluntad del usuario, la situación sugiere que sus recursos fueron vulnerados. El correo de notificación, además de sugerir recuperar el control de sus recursos externos, adjuntará los pasos a seguir para restablecer el acceso a su cuenta, definidos por los protocolos de confirmación de identidad definidos por el consumidor.

Cierre de sesión

BRUTE provee al usuario con tres cierres de sesión distintos: cierre de sesión local, cierre seleccionado de sesión en otros dispositivos, y cierre de sesión en todos los dispositivos, incluido el dispositivo en el que se encuentra ejecutando el cierre.

En general, este proceso está incluido en los vectores de secuestro de cuentas, ya que en algunos casos, usuarios dejan sesiones abiertas en dispositivos accesibles para otras personas; es decir, potenciales atacantes. **BRUTE** busca que el usuario tenga un control completo de sus cuentas, respaldado por protocolos y mecanismos de protección que le permitan proceder con seguridad en cualquier circunstancia, y el cierre de sesión no es la excepción.

Cierre de sesión local

El cierre de sesión local implica revocar el acceso a la cuenta del usuario en el dispositivo en el que se encuentra. Si el usuario quiere acceder a su cuenta nuevamente, tendrá que completar el proceso de inicio de sesión desde el principio, es decir: ingresar su “identifier”, su contraseña, y su OTP.

Este cierre de sesión no requiere revalidación de identidad, y tampoco frena operaciones sensibles en curso.

Cierre seleccionado de sesión en otros dispositivos

El cierre seleccionado de sesión en otros dispositivos implica revocar el acceso a la cuenta del usuario en el dispositivo seleccionado. Si el usuario quiere acceder a su cuenta nuevamente en ese dispositivo, tendrá que completar el proceso de inicio de sesión desde el principio, es decir: ingresar su “identifier”, su contraseña, y su OTP. El cierre seleccionado de sesión en otros dispositivos podrá realizarse desde la interfaz donde el usuario visualiza la información de su perfil, y tendrá a su disposición una lista con todos los dispositivos que cuenten con una sesión activa.

Este cierre de sesión sí requiere revalidación de identidad (contraseña actual y la OTP), ya que se está revocando el acceso a la cuenta del usuario en un dispositivo específico. Esta funcionalidad puede prestarse para intentos de secuestro de cuentas, e interrupción o denegación de servicios. Este cierre de sesión frena las operaciones sensibles que se hayan iniciado desde el dispositivo seleccionado.

Cierre de sesión en todos los dispositivos

El cierre de sesión en todos los dispositivos implica revocar el acceso a la cuenta del usuario en todos los dispositivos, inclusive en el dispositivo en el que se encuentra. Si el usuario quiere acceder a su cuenta nuevamente en esos dispositivos, tendrá que completar el proceso de inicio de sesión desde el principio, es decir: ingresar su “identifier”, su contraseña, y su OTP.

Este cierre de sesión sí requiere revalidación de identidad (contraseña actual y la OTP), ya que se está revocando el acceso a la cuenta del usuario en todos los dispositivos. Esta funcionalidad puede prestarse para la interrupción o denegación de servicios. Este cierre de sesión frena todas las operaciones sensibles, independientemente del dispositivo desde el que se hayan iniciado, ya que es un mecanismo de acción rápida ante un posible escenario de ataque.

Requerimientos no funcionales

Portabilidad

El diseño de **BRUTE** está generalizado en su mayor parte, a excepción de pequeños detalles fáciles de modificar, lo que hace que su integración y/o despliegue sea sencillo en cualquier contexto.

La primera excepción por tomar en consideración, es la naturaleza de “user_id”, que en esta versión de **BRUTE**, tal y como se mencionó anteriormente en este documento, tiene el objetivo de representar una cédula costarricense. Las validaciones desde el *frontend*, hasta la base de datos, deben estar diseñadas de tal forma que aseguren que el formato sea correcto; sin embargo, no se contempla verificar su validez.

La segunda excepción por tomar en consideración, es la naturaleza de “phone”, que en esta versión de **BRUTE**, tal y como se mencionó anteriormente en este documento, tiene el objetivo de representar un número de teléfono costarricense. Al igual que la primera excepción, las validaciones desde el *frontend*, hasta la base de datos, deben estar diseñadas de tal forma que aseguren que el formato sea correcto; sin embargo, no se contempla verificar su validez.

La tercera excepción por tomar en consideración, es la limitación de registro en los números de teléfono. En esta versión de **BRUTE**, se limita el registro de un número de teléfono a un único usuario, que puede utilizarlo en ambos perfiles (si es que el usuario cuenta con un perfil privilegiado, y un perfil no privilegiado).

La cuarta excepción por tomar en consideración, es la definición del “identifier”. En esta versión de **BRUTE**, el “identifier” es la dirección de correo electrónico; sin embargo, esto no es una regla rígida, y queda a criterio del consumidor.

En general, el diseño de “Users”, “User_Phones”, y “User_Profiles” (a excepción de “profile_id” y “profile_type”, cuya existencia es estructural para el funcionamiento de **BRUTE**) queda a criterio del consumidor, que puede efectuar modificaciones según sea necesario. **BRUTE** ofrece este diseño base para ejemplificar un proceso común de registro.

Escalabilidad

El diseño de **BRUTE**, al estar generalizado en su mayor parte, ofrece un alto nivel de escalabilidad. El diseño de la base de datos, y por ende, el código fuente de **BRUTE**, implementan prácticas de diseño y desarrollo que apuntan a trabajar en sistemas de alta exigencia. Estas prácticas marcan el estándar a seguir en las posibles implementaciones que desee incluir el consumidor.

En general, el diseño de la base de datos permite extender las tablas cuanto sea necesario, ya que aplica una buena separación de responsabilidades; es decir, cada tabla se ocupa de una sola cosa. Además, se utilizan múltiples índices de búsqueda y filtrado para optimizar las consultas a la base de datos, como por ejemplo: “UQ_Credentials_Identifier_Active”, que garantiza la unicidad del “identifier” entre credenciales activas, y optimiza la validación de si las credenciales están operativas, o “IX_Tokens_CredId_TokenType”, que facilita las consultas a la base de datos referentes a las tokens, que definen si un usuario está autenticado y autorizado a realizar determinada acción dentro del sistema protegido por **BRUTE**.

Mantenibilidad

El diseño de **BRUTE**, a vista técnica, busca ser claro, jerárquico, y auto explicativo. Tanto la definición de nombres, como la definición y estructuración de sus funciones, estarán caracterizados por manejar los aspectos más generales primero, y los aspectos más específicos de último. Esto, ayudará a todo desarrollador a ubicarse dentro del código, y definir estrategias de búsqueda.

En la base de datos, tanto los nombres de las tablas como los nombres de las columnas son auto explicativos, y la definición de los *constraints* es manual para evitar nombres autogenerados, siguiendo una nomenclatura común, como: “PK_”, “FK_”, “UQ_”, “CHK_”, “IX_”, etc.

En el código...

En otros aspectos, **BRUTE** debe ejecutar tareas automáticas, como la limpieza de archivos huérfanos tras procesos incompletos de registro y/o edición de perfiles, además de la limpieza de credenciales (y sus registros relacionados) que nunca fueron activadas.

Disponibilidad

BRUTE es el encargado del acceso al consumidor, por lo que siempre debe estar disponible y operativo, a excepción de una intervención de emergencia provocada por la explotación en curso de una vulnerabilidad crítica, que implique aislar los entornos protegidos para reducir la superficie de ataque; es decir, que todo el sistema (tanto **BRUTE** como el consumidor) debe ser aislado hasta que la vulnerabilidad sea atendida.

Rendimiento

BRUTE debe ser lo suficientemente rápido para que su intervención sea imperceptible para el usuario. Su diseño debe asegurar un funcionamiento ligero, eficiente, y lo suficientemente rápido para evitar extensos tiempos de carga frente a altos flujos de consultas. **BRUTE** es el encargado de determinar quién

tiene acceso a rutas privadas; es decir, rutas a las que solo pueden acceder usuarios autenticados y/o autorizados, por lo que determinar esta información en el preciso momento debe tomar la menor cantidad de tiempo posible.

Los índices de búsqueda y filtrado son pilares fundamentales en este aspecto, como el “IX_Tokens_CredId_TokenType” descrito anteriormente, además de un diseño óptimo de las funciones: que utilice los recursos necesarios para ejecutar procesos, que no realice consultas innecesarias, que no cargue datos innecesarios.

Seguridad

BRUTE debe asegurarse que todos sus procesos sean seguros, precisos, y herméticos. Primeramente, el *endpoint* de registro y de inicio de sesión deben estar protegidos por un *rate limiting*, para evitar ataques de denegación de servicios, o, ataques de fuerza bruta.

Todas las *cookies* que emita deben ser “HttpOnly”, “Secure” y “SameSite = strict”, ya que son las encargadas de ‘manejar’ las tokens del lado del usuario, por lo que el mayor grado de protección que pueda ser alcanzado desde su generación en el servidor resulta indispensable. Las tokens deben ser únicas, y deben ser hashadas empleando el algoritmo “SHA-256”. Además, las tokens de refrescado deben estar restringidas a un único *endpoint*, para evitar su uso fraudulento.

Las contraseñas deben estar hashadas **sin excepción**, al igual que otras credenciales del mismo estilo, como por ejemplo: PINs, OTPs propias, etc., que puedan ser implementadas por el consumidor.

Los secretos del MFA deben estar cifrados, y es importante reiterar que el MFA es **obligatorio** para cada cuenta **sin excepción**, ya que es una de las principales barreras de protección de las cuentas de los usuarios, tanto en la autenticación, como en la autorización de operaciones sensibles.

La separación de perfiles implica la separación de credenciales. **BRUTE** no debe permitir que un perfil privilegiado comparta credenciales con un perfil no privilegiado, con el objetivo de reducir la posibilidad de robo de credenciales privilegiadas, y reducir la superficie de ataque.

La dirección de correo electrónico es el principal canal de comunicación entre **BRUTE** y el usuario, y mediante él se completan todos los procedimientos referentes a la cuenta. La integridad del correo como del MFA es fundamental, ya que si alguno de los dos recursos resulta comprometido, **BRUTE** no puede garantizar la seguridad de la cuenta.

La deshabilitación de cuentas implica el bloqueo permanente del “identifier” con el cual se deshabilitaron.

Trazabilidad

El diseño de **BRUTE** debe ofrecer trazabilidad de los hechos por sí solo. Todos los registros completados deben mantenerse físicamente, y en caso de que alguno de ellos deba ser deshabilitado, deberá ser mediante un borrado lógico.

BRUTE, por ejemplo, registra: cuándo se registró un usuario por primera vez, cuándo se generó y se entregó la información de su MFA, intentos de acceso fallidos, cuánto tiempo serán bloqueadas las credenciales de un usuario, y en general, sus tokens (qué acción estaba realizando el usuario, cuándo se generó, cuándo expiró, y el dispositivo al que está ligada).

Decisiones técnicas

BRUTE es un proyecto multipropósito. Las decisiones técnicas giran en torno a la construcción de un proyecto de aprendizaje, que alcance los estándares de productos comerciales.

Stack

TypeScript

TypeScript agrega tipado estático sobre JavaScript, lo que permite detectar errores en tiempo de desarrollo en lugar de en tiempo de ejecución. En un sistema como **BRUTE**, donde la precisión de los datos es crítica, tipos incorrectos en credenciales o en tokens pueden generar vulnerabilidades silenciosas, por lo que el tipado estático actúa como una capa adicional de validación durante el desarrollo.

Además de ser el lenguaje natural del ecosistema de NestJS y TypeORM, mejora la generación, mantenibilidad y legibilidad del código.

NestJS

NestJS es un *framework* moderno con ecosistema amplio y activo, que impone una arquitectura clara de separación de responsabilidades desde el inicio. A diferencia de alternativas más minimalistas, como Express o Fastify, NestJS define convenciones estructurales que facilitan la escalabilidad y mantenibilidad del proyecto, reduciendo la ambigüedad sobre cómo organizar el código. Su curva de aprendizaje es ligeramente más marcada, pero el beneficio en claridad arquitectónica justifica esa inversión inicial, especialmente en un sistema modular y reutilizable como **BRUTE**.

TypeORM

TypeORM está fuertemente integrado con TypeScript y NestJS, lo que mantiene consistencia en el *stack*. Su modelo de trabajo basado en entidades y decoradores permite replicar la estructura de la base de datos con precisión, asegurando que los tipos de datos sean correctos en todo momento y reduciendo la posibilidad de errores silenciosos de tipo. Facilita la delegación de lógica automática al motor de base de datos de forma declarativa, y su API de CRUD es simple y legible. A diferencia de alternativas como Prisma, que abstrae más el SQL subyacente, TypeORM permite mantener control sobre el esquema sin perder la comodidad de trabajar con objetos.

El esquema de base de datos es definido manualmente, y TypeORM se utiliza exclusivamente para el mapeo y la interacción con ese esquema, no para su generación. Esto garantiza que *constraints*, índices, y lógica de base de datos queden bajo control explícito del desarrollador.

SQL Server

Motor empresarial robusto, ampliamente adoptado en entornos corporativos, lo que refuerza considerablemente las capacidades de escalabilidad y mantenibilidad de **BRUTE**.

El esquema de **BRUTE** aprovecha características específicas de SQL Server como “DATETIME2”, “NVARCHAR”, índices filtrados con cláusula “WHERE”, y *constraints* nombrados manualmente, que están completamente soportadas y bien documentadas en este motor. La versión Express es gratuita y suficiente para el alcance de **BRUTE**, aunque versiones de mayor escala implican costos de licenciamiento que el consumidor debe considerar al momento de adoptar el sistema.

Arquitectura

Separación de identidad, perfil y credenciales

El modelo de datos de **BRUTE** separa explícitamente tres conceptos: la identidad del usuario (“Users”), su perfil (“User_Profiles”), y sus credenciales (“Credentials”). Esta separación no solo es una decisión de diseño, sino una necesidad estructural: **BRUTE** soporta dos perfiles por usuario (privilegiado y no privilegiado), por lo que la identidad del usuario no puede actuar como llave primaria de los perfiles, y, consecuentemente, de las credenciales, ya que cada perfil cuenta con sus propias credenciales para reducir la superficie de ataque por robo de credenciales.

Cada concepto ocupa su propia tabla con su propia responsabilidad, lo que además facilita búsquedas filtradas por contexto y permite extender cada entidad de forma independiente sin afectar lo demás.

Doble perfil por usuario

BRUTE es agnóstico al dominio del consumidor, por lo que no contempla un sistema de roles tradicional. En su lugar, define dos tipos de perfil (privilegiado y no privilegiado), que permiten centralizar los privilegios dentro de un único tipo, imposibilitando que perfiles no privilegiados accedan a funcionalidades restringidas por accidente, o por vulneración. El significado concreto de cada tipo de perfil queda a criterio del consumidor.

Es importante esclarecer que **BRUTE** contempla el registro de cada perfil en entornos completamente separados, en el que el registro de perfiles privilegiados se realiza en entornos privados, herméticos, y sumamente controlados, mientras que el registro de perfiles no privilegiados se realiza en entornos públicos.

El correo como canal de comunicación universal

Todas las operaciones que requieren confirmación o notificación al usuario se realizan a través del correo electrónico. Esta decisión simplifica el modelo de comunicación, ya que contempla un único canal de confianza para todos los procedimientos; pero, a costa de una limitación conocida y documentada: si el correo del usuario está comprometido pero el MFA no, **BRUTE** puede seguir garantizando la seguridad de las operaciones sensibles, ya que ninguna puede completarse sin ambos factores.

Sin embargo, la seguridad de la cuenta en su conjunto depende también de lo que el consumidor permita ejecutar dentro de una sesión activa sin requerir una operación sensible.

Modelo de datos

“user_id” como identificador de identidad

En esta versión de **BRUTE**, “user_id” representa la cédula costarricense del usuario. Esta decisión garantiza que cada persona física tenga un único punto de identidad dentro del sistema, independientemente de cuántos perfiles tenga registrados. A diferencia de un identificador autogenerado, como un “UUID”, la cédula elimina la posibilidad de duplicados de identidad real, centralizando todos los perfiles de una misma persona bajo un único valor de identificación verificable.

Estados de credencial

BRUTE define seis estados para las credenciales: “PENDING”, “ACTIVATED”, “LOCKED”, “BLOCKED”, “REACTIVATING”, y “DISABLED”. Cada estado representa una condición distintiva y mutuamente excluyente de las credenciales, lo que permite que el sistema tome decisiones precisas en cada punto del flujo sin ambigüedad. La nomenclatura fue elegida por su generalidad, evitando términos como “SUSPENDED”, que podrían ser reinterpretados por el consumidor como un estado propio de su dominio.

Índice de filtrado “UQ_Credentials_Identifier_Active”

BRUTE permite múltiples registros con el mismo “identifier” en estado “PENDING”, restringiendo la unicidad únicamente entre credenciales con un estado distinto de “PENDING”. Esta decisión responde a una necesidad de seguridad específica: si el “identifier” fuera único de forma absoluta, un atacante podría bloquearlo durante el periodo reservado para la activación de las credenciales, impidiendo que el usuario legítimo complete su registro. Permitir múltiples registros “PENDING” simultáneos neutraliza ese vector, garantizando que solo uno pueda ser completado, mientras que el resto serán invalidados automáticamente.

Evaluación “lazy” de “locked_until”

El bloqueo temporal de credenciales no se gestiona mediante un proceso automático que desbloquee las credenciales al expirar el tiempo, sino que se evalúa en el momento de iniciar sesión. Esta decisión reduce la cantidad de responsabilidades activas del sistema: no requiere un *cron job* adicional, consume menos recursos, y el resultado observable para el usuario es idéntico: si el bloqueo ha expirado, el inicio de sesión procede con normalidad.

Seguridad

Uso de “crypto.randomBytes(32)” para generación de tokens

Las tokens se generan utilizando “crypto”, el módulo criptográfico nativo de Node, que emplea un generador de números aleatorios criptográficamente seguro, a diferencia de alternativas como “Math.random()”, que no lo son. 32 bytes producen 256 bits de entropía, lo que garantiza que cada token sea suficientemente única y aleatoria para su propósito, complementándose directamente con el algoritmo de hasheo empleado.

Uso de “SHA-256” para el hasheo de tokens

Las tokens generadas son hasheadas empleando “SHA-256”, algoritmo que produce datos suficientemente extensos para evitar colisiones, y suficientemente rápido para su objetivo: generar una llave de acceso o autorización en el momento preciso para su uso, regularmente, inmediato. Alternativas de mayor longitud quedan descartadas por ser innecesarias para este caso, ya que la seguridad de la token proviene de la aleatoriedad de su generación, no de la longitud de su hash.

BCrypt para hasheo de contraseñas

Las contraseñas son hasheadas empleando BCrypt, algoritmo ampliamente adoptado en el ecosistema de Node, diseñado deliberadamente para ser lento. A diferencia de “SHA-256”, cuya velocidad es una ventaja para el hasheo de tokens, en el contexto de contraseñas la lentitud es una característica de

seguridad: dificulta significativamente los ataques de fuerza bruta contra contraseñas hasheadas, y su coste adaptativo permite ajustar su intensidad según las capacidades del sistema.

MFA obligatorio

El MFA es obligatorio para todas las cuentas sin excepción. La principal responsabilidad de un sistema de autenticación es proteger la identidad del usuario, y el MFA es una de las barreras de protección más efectivas disponibles: no solo protege al usuario, sino también al sistema que **BRUTE** resguarda. Ofrecerlo como opcional abriría una superficie de ataque innecesaria, ya que los usuarios que no lo activaran quedarían protegidos únicamente por su contraseña.

Bloqueo progresivo

El bloqueo progresivo está diseñado para equilibrar seguridad y experiencia de usuario. Los primeros intentos fallidos no generan bloqueo inmediato, ya que es razonable que cualquier usuario cometa errores ocasionales. A partir del quinto intento, se aplican bloqueos temporales de duración creciente, que advierten al usuario de la situación y reducen progresivamente la capacidad de ataques de fuerza bruta sin ser excesivamente rígidos desde el inicio. El bloqueo permanente en el octavo intento actúa como una medida de seguridad definitiva ante un ataque sostenido.

Casos límite

Fallo del servidor de correo durante una operación sensible

Todos los procesos que implican el envío de un correo están respaldados por transacciones. Si el envío falla, la transacción se retrae automáticamente, deshaciendo cualquier cambio efectuado en la base de datos durante ese proceso. El usuario recibirá una respuesta negativa genérica que le indicará que algo salió mal, y que debe intentarlo nuevamente.

Colisión de hash de tokens

Inmediatamente después de generar una token, **BRUTE** genera su hash y verifica su unicidad contra los registros existentes en la base de datos. Si el hash colisiona con uno existente, **BRUTE** fuerza una regeneración de la token y repite el proceso hasta obtener un hash único antes de persistir.

Condición de carrera en el registro simultáneo

Si dos procesos de registro con el mismo “identifier” se completan simultáneamente, el motor de la base de datos determinará cuál persiste primero, gracias al índice de filtrado: “UQ_Credentials_Identifier_Active”. El proceso que no logre persistir, propagará el error generado por el índice de filtrado hasta el usuario, que recibirá una respuesta negativa genérica que le indicará que algo

salió mal, y que debe reintentarlo nuevamente, y, cuando lo haga, **BRUTE** le indicará que esa información ya está en uso.

Cierre de sesión sobre una sesión ya cerrada

Si el usuario intenta cerrar una sesión que ya expiró o fue cerrada entre el momento en que cargó la lista de sesiones activas y el momento en que ejecutó el cierre, **BRUTE** retornará un mensaje de error específico al *frontend*, que deberá re-renderizar la lista de sesiones activas con los datos actualizados, e informar al usuario que esa sesión ya estaba cerrada.

Usuario no privilegiado sin acceso al correo durante reactivación

Si el usuario no cuenta con acceso a la dirección de correo electrónico asociado a su cuenta, y se encuentra en medio de un proceso de reactivación de credenciales, el proceso se invalidará automáticamente. La modificación de información desde fuentes internas representa un potencial riesgo de secuestro de cuentas y/o denegación de servicios, además de que rompe los principios de protección de **BRUTE**.